BGIN Block#11 Meeting Report

- BGIN is a multi-stakeholder discussion body / distributed think tank.

Cybersecurity Information Sharing Alignment

bg in

blockchain
governance
initiative
network

The Global Network for Blockchain Stakeholders™

© 2023 BGIN (Blockchain Governance Initiative Network) is registered as BN Association, a Japanese general association with its principal place of business at Shiba Building, 704, 4-7-6, Shiba, Minato-ku, Tokyo. All rights reserved.

The know-how described in this document was made available from contributions from various sources, including members of the BGIN and others. Although the BGIN has taken steps to help ensure that the know how is available for distribution, it takes no position regarding the validity or scope of any intellectual property or other rights that might be claimed to pertain to the implementation or use of the know how described in this document or the extent to which any license under such rights might or might not be available; neither does it represent that it has made any independent effort to identify any such rights. BGIN and the contributors to this document make no (and hereby expressly disclaim any) warranties (express, implied, or otherwise), including implied warranties of merchantability, non-infringement, fitness for a particular purpose, or title, related to this document, and the entire risk as to implementing this document is assumed by the implementer. The BGIN Intellectual Property Rights policy requires contributors to offer a patent promise not to assert certain patent claims against other contributors and against implementers. BGIN invites any interested party to bring to its attention any copyrights, patents, patent applications, or other proprietary rights that may cover technology that may be required to practice this document.

BGIN Block#11

Cybersecurity Information Sharing Alignment in the Crypto Industry

Date: Monday, October 22, 2024

Location: Washington DC, United States

Duration: Approx. 90 minutes

Summary

On-Chain Threat Detection:

- Offers unique advantages in visibility, tracking, and proactive prevention, distinguishing it from slower Web2 response times.
- Collaboration with companies developing on-chain security technologies aims to improve risk management.

Information Sharing and Threat Landscape Monitoring:

- Beyond identifying vulnerabilities, sharing broader risk-related insights is crucial for industry preparedness.
- Emphasis on understanding attackers' motivations—whether financial theft or systemic disruption—guides tailored defense strategies.

ISACs (Information Sharing and Analysis Centers):

- Originated in 1998 to protect critical infrastructure (e.g., gas, electric grids); evolved to address cyber-focused threats.
- Financial ISACs are essential due to increasing cyber threats against financial institutions.
- ISACs function at both regional and international levels, adapting to specific regulatory and industry needs.

Stakeholders in Blockchain Security:

- Key stakeholders include government, wallet providers, admins, network layer participants, miners, validators, stakers, application layer actors, and crypto exchanges.
- Foundations managing protocols are unique to blockchain, adding a transparency layer but also increasing potential vulnerabilities.

Open Source Vulnerabilities:

- Similar to traditional software, blockchain open-source development requires vigilant sharing of vulnerability patches.
- Exploitability in blockchain is immediate and highly liquid, incentivizing swift responses and well-designed bug bounty programs.

STIX and TAXII Standards:

- Widely used for cybersecurity information sharing but lack fields specific to blockchain (e.g., smart contract addresses).
- Custom extensions are costly; there's consensus to extend STIX and TAXII rather than invent new standards.
- Privacy and responsible disclosure remain central, with open-text fields and customization for sharing cybersecurity data.

Data Standardization and Privacy Considerations:

- Blockchain industry lacks consistent data formats; some existing standards from other sectors may serve as models.
- Discussions around data types, including wallet addresses as Personally Identifiable Information (PII), highlight privacy challenges.
- Zero-Knowledge Proof (ZKP) technology could enhance privacy by protecting sensitive data in shared information.

Cyber Insurance and Investment Confidence:

- Mapping vulnerabilities and understanding threat intelligence helps insurance and investment sectors assess ecosystem risk.
- Shared best practices and international frameworks, such as CISA and FS-ISAC, promote secure infrastructure and data privacy.

Vulnerability Disclosure and Bug Bounties:

- Responsible disclosure practices and bug bounty programs are crucial for managing vulnerabilities in blockchain.
- Crypto ecosystems face unique challenges with on-chain extortion and immediate exploitability, requiring proactive and structured responses.

Transcript

Hey, everyone, sorry for coming in right as we were getting started, but I'm thrilled to discuss an issue that has long been a point of discussion at BGIN, focusing on cybersecurity information sharing alignment with the crypto industry and why this is so critical. Thanks to the whole group

coming into DC. I'm excited to meet with all of you. I've met with many of you around the world, and now, finally, here in my hometown in DC.

In this discussion, we want to kick off with a presentation from the BGIN crew to highlight some of the foundational aspects we've previously discussed, the framework BGIN has put together for structuring how we think information should be shared. For context, many know what an ISAC is, and most people here have participated in BGIN discussions historically. The Information Sharing and Analysis Centers (ISACs) originated from an understanding in the cyber domain that the only way to keep pace with the internet's speed was to allow cross-industry information sharing. Recognizing a cyber threat against one entity or competitor wasn't advantageous because the attackers would target others too. Thus, the need to share information in an interoperable and machine-readable way, at the speed of the internet, emerged to help good actors combat bad actors operating at great speed and scale.

There's an ISAC for each critical infrastructure sector in the US, encompassing 16 sectors from energy to transportation and aviation, the financial services ISAC, and the defense industrial base. Recently, we've seen several ISACs emerging in the cryptocurrency and blockchain ecosystem, intersecting financial services and information and communications technology. The ISACs enable faster response times by pooling threat intelligence, making it possible to combat malicious activities with shared knowledge and tools.

In the age of crypto, we now deal with both illicit cyber activities and "cyber money," which includes illicitly used funds. The vast amount of machine-readable data in crypto presents new possibilities for structuring information sharing. BGIN has delved deeply into this, and A BGIN crew will speak to some of the history and the structure BGIN has developed for today's discussion.

Yes, thank you. I believe many of us here are familiar with this diagram, but I'll explain it briefly. This represents the general flow of cybersecurity information sharing alignment in the US. We start with responsible disclosure practices, where individual researchers and security professionals discover vulnerabilities in vendor products and report them directly to vendors, allowing for the creation of security patches. If vendors fail to respond, researchers can report vulnerabilities to the CVE Program, managed by MITRE, which will then ask the vendors to create security patches. The CVE list, managed by MITRE, is analyzed and standardized by NIST, then included in the National Vulnerability Database.

Various ISACs across industries analyze information from the CVE Program and National Vulnerability Database, sharing sector-specific threat information and best practices with industry vendors. Platforms like STIX and TAXII enable the sharing of threat intelligence across sectors. This is the general cybersecurity alignment in the US, but the crypto industry lacks similar alignment. We have questions about responsible disclosure practices, such as whether they work effectively in Web3 and blockchain. MITRE currently manages CVE programs, but

should they also handle vulnerabilities in crypto? Should information sharing be global rather than national? And do we need a specific data format for crypto-related vulnerabilities? The CyptoISAC was recently established in the US, and we're interested in discussing its role in this ecosystem and whether existing platforms like STIX and TAXII are adequate for integration or if new solutions are required. We also want to explore how BGIN can contribute to establishing effective information sharing in the crypto industry. This covers my presentation.

Thank you. We love the flowchart. The ISACs, initially created for cyber threats, have clear applications in cryptocurrency as well. Our goal is to address national security threats through frameworks like ISACs, leveraging them for sharing not only cyber threat information but also broader intelligence. The current session isn't focused on threats, but I'm happy to dive into that if it's helpful. For now, though, let's focus on ISACs.

I'd like to start with a member of CryptoISAC. Could you share the Crypto ISAC's formation, current focus, and specific needs or unique aspects within the blockchain ecosystem?

Hello, everyone. Our focus at the Crypto ISAC is cyber threat intelligence sharing, covering tools, tactics, procedures, and indicators of compromise. Our members include private companies from diverse areas within the blockchain and crypto asset space, like infrastructure protocols for L1s and L2s, security firms developing on-chain monitoring technologies, investors in Web3 startups, stablecoin providers, exchanges, wallet security, and wallet technology providers. We aim to foster information sharing across this ecosystem.

Our primary focus at the Crypto ISAC is a two-way information flow of indicators of compromise unique to the crypto industry. We discuss Web2 and Web3 IOCs and their differences, expanding our focus beyond vulnerabilities. On-chain threat detection offers exciting capabilities for visibility, tracking funds, scanning for vulnerabilities, and even preemptively intervening to prevent exploitation. Unlike in Web2, where response times are slower, blockchain allows us to track vulnerabilities and proactively prevent hacks. We're working with companies developing on-chain security monitoring technologies to advance proactive risk management.

The Crypto ISAC engages with a broad range of stakeholders. By sharing more than just vulnerabilities, we help the industry identify and address risks. This high-level overview highlights our focus on threat landscape monitoring and addressing industry vulnerabilities.

Thank you. The unique on-chain visibility in crypto is a powerful tool for threat detection and prevention. Next, I'll turn to a participant, who was involved in the initial setup of the financial services ISAC and has insights from his experience with many ISACs. Could you share some history and your thoughts?

Sure. ISACs were created in 1998 under Presidential Policy Directive 63, envisioning mutual protection across critical infrastructure sectors. Early ISACs focused on protecting assets like gas pipelines and electric grids from cyber threats. As technology evolved, software vulnerabilities required attention, eventually leading to cyber-focused ISACs. The financial services ISAC became essential as cyber threats increasingly targeted financial institutions. Today, we must also consider the intelligence behind these threats—understanding the attackers' motivations, whether it's financial theft or systemic disruption, informs how we respond. The federal government emphasized cyber threat intelligence, urging that we move beyond indicators like IP addresses or domain names and understand the campaign methodologies and attackers' motivations. For example, nation-state attacks require a different response compared to those from criminal gangs. By focusing on understanding these motivations, we can tailor our defense strategies.

Let's open the floor for discussion. This concept of sharing specific indicators, wrapped in broader analysis, is essential for crypto as we combine cyber and financial threat intelligence. In the crypto world, we face technical and financial vulnerabilities, so understanding both is critical. Let's discuss how this context applies to crypto and where CVEs and vulnerabilities fit in this ecosystem. We have that blockchain industry companies here so open it out here.

Developers operate it with other very different types of people. of course that we have you know the custom of the script if blockchain services you know some of them uses you know non-custodial work. That's kind of order that is not provided by the company. and then anyway so we need to identify that what kind different types of stakeholders are in this world and then the other thing so what kind of information the lead stakeholders truly want. The side of the point is we have three different types of planning when something happens. So it's a general so it's an event so what we do when something happened. And what we do when not see public. So what do we do so when Not properly yet so we have three different time frames. Information needed to be exchanged should be different. But there's these three types. And so they have three angles. One is who is the stakeholders? the second is what kind of information should we exchange? And there's a win that suspicious type of single machine should be changed. That's kind of just things that needed to discuss. responsible date.

Yeah, so… I was wondering So they're supposed to be or there is going to be multiple ISACs around the world And… And each of the ISACs will have access to different communities and they'll make arrangements or work with them. And the reason why this presentation was done at BGIN is we're trying to figure out how that coordination is going to be, right? It's not like there's going to be one ice hack that covers the entire globe. But That's not the case, right? That would be far too centralized yes yeah that um I do expect that there will probably be many ISACs the same way that there is in the cybersecurity ecosystem. Also just knowing that as was joked in here, that that would be far too centralized for a decentralized community to likely adopt.

So of course, like part of these ecosystems on like whether we think that they'll always be nationally driven versus international, I do think that I think that both are going to likely play a role in the ISACs because of the nature of these highly distributed, like on digital platforms, like business operations that occur without regard for borders. in their business practices will also then necessarily inherently demand that kind of information sharing partnerships to also cross borders with probably some globally reaching ISACs, but also some unique ones that like have unique considerations around how they can handle information. maybe related to the threat picture, but I think especially around things like regulatory construct and their own unique regulatory environment and other things will end up meaning that you'll get some regional or nationally focused partnerships, but then also several that are focused internationally. So I think it'll be hybrid is what I imagine. I don't know if the group feels the same way.

Cool. And that's helpful as a tee up into the first question about who are the stakeholders here. And thank you for that, because I think that probably helps us in mapping out. you walked through several of them. I'll prompt the group in thinking about the types of stakeholders and maybe we can carry through the entire flow of what happens when a vulnerability is created, when it exists, when it's identified, exploited, and then what happens along the way. So let me walk through this and then ask the group for reactions. So the first stakeholders, you have the people responsible for creating the thing that has a vulnerability issue. So you've got devs, right? And then you have the people responsible for exploiting that. Awesome. They're a stakeholder and whether or not we get this right. If we get this wrong, they do a lot better in stealing our money and putting our infrastructure, right? So they're a stakeholder, not one we want to engage with, just one we need to keep in mind when we're thinking about how timely we need to take action here. So ignoring the bad guy, we put red aside for a second and focus on blue. So we've got the developers and then we've got the people that are actually building and implementing this infrastructure and these business operations.

If we think about the different levels of the tech stack, we have people responsible for hardware and cold storage wallets. We definitely have companies, so we have wallets, we have admins, we have network layer and miners and validators and stakers. We have application layer, the people responsible for that, which includes crypto exchanges. And then we have broader like markets and users. I don't know. That's sort of a very rough walkthrough. What do you guys think? What are some of the other types of stakeholders that we have when we think about who, yeah, I'll just stop here, then we'll get into who then has the best information but who are the key stakeholders? where the vulnerabilities exist that are being exploited. Like we just talked about a bunch of them. So like wallet, miners, validators, exchanges, yeah, like admins like at the protocol level, who are some of the other types of stakeholders that we have?

Why do you care about all this? I mean, what I care about is because Lazarus Group is using your industry as open ATMs, and I'd like them to stop. So in order for us to do that, we need to patch these vulnerabilities on the technological side and share that information to make sure that

these systems are more secure. And then when they do when they do get pwned, because even in cyber, we say it's not when it's not if it's when you get hacked, then we need to have the ecosystem in place and the mitigations to make sure that we can go mitigate those consequences. But in a lot of cases, that means stopping that money from getting to that bad guy and stopping it from being cashed out. So both of those sides, those are my main objectives. So you would agree that government is a stakeholder? Oh, yes. Good point. Yes, we are a stakeholder, of course. Sorry. On the government side. Sorry. It was important for you to explain why. Absolutely right. If I highlight the bad guy, you should highlight also the government, not the bad guy. I just left another interesting stakeholder that has massive stakes in whether or not we get this right and making sure that the bad guy isn't very successful. So great, great point. Thank you.

Awesome. Any other types of stakeholders we've missed on who owns the vulnerability? I'm not saying liability, that's a different issue that I'm not going to dissect here, but who has the vulnerability that's being targeted. And we mapped them all out in that place and the flow that we've just discussed.

that both users of blockchain services you know the most important security of what you said because the water is the touch point of the general use of the property services on blockchain and the production services and so I would think about who provide a word to the people in many cases with a profound company like a coinbase or something like that we'll provide that so quick but then you know crypto work to the general people but then in some cases, Bitcoin for software is a word itself but there is no centralized, that is just improved the warrants that you know this is a noncastle warrant there's no responsible party there for the time warrior. Yeah, I guess then it just depends on there's like the level of responsibility like like if they would be the ones holding the asset versus like there still is a stakeholder, again, liability might like look different for something that's non-custodial, but there is somebody who did like design the software for that for that wallet, even if it's a non-custodial wallet solution. So there's an opportunity there to make sure that we have a stake and the users have a stake. I like your focus on starting with the user because that's the person that's getting hurt the most. So going out from there, maybe that's a good way to think about it.

But then we're thinking about who's responsible for the wallet. If it's a big exchange like Coinbase and other types of companies that are highly regulated, it's easier to wrap your arms around them versus a lot of non-custodial solutions. You end up having developers that may or may not be financial institutions in many cases would not be. And so then like, but they're a stakeholder that like the user is relying upon to do this well because that's the software that they're using to keep their assets safe. So a great point.

One thing that I find quite interesting, which is different in the blockchain space. And it's definitely considered a stakeholder is the foundation or the organization that holds the repos and makes updates to the protocols And we spoke about this in the Tokyo meter, which does a really

interesting comment from one of the Con developers where they actually noticed a vulnerability in the code And they didn't publish the update to Bitcoin Core citing the vulnerability. They published an update on something trivial and then fixed the vulnerability like under a guise. And I think that that was very intentional because of the way that like fluctuations are developed and the layering of this So like if you could then let's transpose that to the Ethereum community you've got the Ethereum blockchain which has all these amazing like research level updates which can create vulnerabilities. But then there's layers and layers and layers of people who copy the Ethereum blockchain and use EVM, which can create vulnerabilities that are not updated in real time or don't understand the update that was be done to fix the vulnerability, if that makes sense. So I think that that's the transparency in crypto around the development is something that we have to consider quite seriously because If you update a vulnerability and everyone sees that that the patch was to update a vulnerability, those people can then go to the smaller networks. Have they fixed that problem as well right like so if you've got an Ethereum layer two like base network that didn't like, I don't expect this to be the case, but this is just an example that didn't fix a vulnerability that the Ethereum main chain fixed. they could be exploited significantly. And I'm pretty sure this is where like the harmony hack happened. I think why that happened, but yeah.

Yeah, I love that use case. And there's like, I guess, thinking about, again, back to traditional ecosystems like the open source software community, since so much of this is built in open source communities, it's a lot of the same constructs and opportunities for thinking about where the expertise lies, where vulnerabilities get uncovered, and then how that you share across broader ecosystem that's using and relying upon those open source libraries that may have those vulnerabilities in them. So that's, yeah, I think I really appreciate that. Thank you for walking. So maybe the repo itself. The repo itself. Yeah, I think that's really interesting and As a stakeholder that I hadn't thought about before i like that

So others about specific stakeholders. I know we talked about who owns like where the vulnerability exists I'll talk about very briefly now like types of stakeholders. So then we have like who would have the information or see that a vulnerability has existed, which some of the same people in some cases others like security researchers and others that don't own the vulnerability, but maybe they're the ones that see it. And then you have who has the ability to do something about it. Again, a lot of these are the same stakeholders, it's just different parts of the flow of responsibility and ecosystem.

I know this is a surprise call on you, but thinking about that in the cyber domain, as well as if you have views on the crypto domains, I know that the Institute for Security and Technology has done work across all these. If you have thoughts about identifying different types of stakeholders across this kind of flow of who has stakes in us getting this right or wrong, but then who owns the vulnerability, who sees it the best, and then who is positioned to do something about it, mapping out those different types of stakeholders would love your thoughts.

Thanks. I am probably the least informed in the room. We lead the ransomware task force outside the government and among other things, they're particularly concerned about the role that crypto plays in the ransomware ecosystem. And so, like Carol are also interested in working to close any gaps that exist between different stakeholder communities in this space One that comes to mind is you've been talking about identification of stakeholders, sometimes it's useful to As being all as it may seem to do a TTX tabletop exercise. follow the money, so to speak follow the vulnerability in this case, which can make the money. on the other side. Certainly, and as that process i think takes place thinking about hopefully where there might be better opportunities that could be established or developed to facilitate better communication between the research community, security researchers and the stakeholders here where there may not a greater ability of trust you mentioned between security researchers and all of these stakeholders, but when we think about stakeholders that I've identified in the blockchain ecosystem. Someone was sharing the story yesterday that they have something on the odds of maybe 400 API keys that belong to Microsoft customers and person is trying to share them with Microsoft and phone calls being unanswered. So that means that there are multiple opportunities for there to be vulnerabilities leveraged there. So closing those types of relationships both between different stakeholder groups, and I think tabletops can be useful in that they also tabletops help to build trust um I think the other thing that came to mind is just thinking about Again, I don't know the space as well but I would encourage you all to not try and reinvent the wheel i mean the leverage the wheel that exists. So we do have STIX and TAXII. Of course, it has its naysayers but the community that exists that's in managing cybersecurity risk over 30 plus years understands this space and so bringing a new set of a new technical set of standards, I think may result in delays when we really need to turn off the faucet that Lazarus is exploiting and a number of other things so Just a few random thoughts.

Thank you. Appreciate it. And I think that's helpful as we think about them, like what is sort of unique or special or where there are corollaries in these types of stakeholders, where a lot of these guys at the network layer, you might think about as them and the kind of role that they can play like internet service providers do. Obviously those companies and others are responsible for applications, etc, the same kind of construct that we use in the cyber domain may end up being directly applicable here. But then what's also sort of unique and hasn't been identified yet. So on, sorry, were there others who wanted to comment so far on the stakeholders? Oh, sorry, was there a hand raised?

Yes. Hello, everybody. I hope you can hear me. Yes. Can you? Good. Yes, very good conversation. Thank you very much for setting this up. a comment and a question I think one aspect was discussed only briefly which is motivations of all these diverse stakeholders And why they would participate in this information sharing. And that leads me to actually the comment made by a previous speaker, I think you mentioned that in the crypto world that's very international, naturally decentralized to a very large extent. Anyways, the question is about cost benefit. Somebody will benefit and in the traditional world, it's relatively straightforward

vendors they want to sell, they want to make money. That's why they need to be secure. The users naturally also want security and government supervised stability. That's what they want. In the decentralized world, motivations are completely different So when we talk about the crypto ISAC. What's the business model there? There are 20, 30 members, do they pay membership fees. How big is the fee? And if somebody does not pay a fee is not a member, how will they benefit from information sharing?

So that's really interesting. And maybe that helps us transition into the second part of a previous question asked too about what info we share. Let's try to bridge that gap between this examination of your point about incentives and how they're different. or not. But in a lot of cases, the attendance may not be quite so different, but I really like starting from your point that decentralized communities do have a different ethos that drives the construct of why these communities are driven and created in such decentralized ways. So what help us think about like if anyone wants to start some of the discussion, maybe I turn to you about how how do you think that some of the incentives and motivations for players in the DeFi space might look a little bit different and how that may drive what we share. Can I turn to you on that? Thanks.

Love the top question. I tend to look at this first through a TradFi lens. Not because I love history, but because there's now upwards of 100 billion worth of crypto assets that are now intermingling with the traditional financial system. So two years ago, this bifurcation of TradFi and DeFi, I think those barriers are coming down And if you look at an ISAP model for crypto, I think to get broader support and economies of scale and scope. in the industry at large to make it look as much like a financial services ISAC helps with the selling. So 20 years ago. How is all this solved, particularly after Zion 11 Awesome. Not to go too far down memory lane, but right after 9 11 when the FBI needed to figure out who the hijackers were. they have to deep dive through boxes of fiscal checks in clearing houses around the country. and that's that added time and complexity and cost of the entire investigation kept the country at loose end. at the end of it, that became the catalyst for transformation. where all those checks that are now sitting in your mobile device, they were all digitized. All that technology existed 10 years prior. Nobody wanted to move forward with it until something compelling happened.

Well, fast forward to today, something compelling is happening. And when the motivations are set out. in terms of not just regulations but to go back to the business case and the earlier question. Ultimately, it comes down to how you price your risk as an organization. And companies, particularly financial institutions, have to price their risk different ways, but they also have to ensure their risk. I think you worked with my old friend. So one of the things they did was make sure that their capabilities and vulnerabilities were successfully tagged and they got aligned with the insurance industry. Why was that important? Well, insurers love to share information. Because not only does it lower their beta individually, but they have an entire reinsurance market on the back end that they have to pull that risk. do something against. So long answer to a short question, but I think this has to look like risk management has to look a little

bit like traditional finance financial services or my side And I think it all begins with a reference architecture that everyone can look at objectively and say, all right, here's where I can I'm sure good as a stakeholder, here's where I've got a piece of it And here's where i'm a potential I love a hybrid view.

Thank you so much. And that highlights, I think, again, where some of the same incentives exist, where like the DeFi community is super interested in insurance, right? Like in the space, a lot of that ends up being cyber insurance just specifically for crypto platforms. But I know from a government perspective, we often look to either insurance and the investment communities as the two indicators on like, how is the industry doing on its own?

on hedging and assessing risk. And if there's not thriving insurance and investment markets, then maybe we're not doing so great on being able to measure and assess those. Being able to map and identify vulnerabilities and feeling confident that we can identify when they exist certainly gives confidence to those that are trying to figure out whether or not to invest money or to underwrite an insurance policy in the ecosystem. So I really appreciate it. Thank you so much, Frank, for pointing to those really important motivations and levers in the space. I think that there was a hand raised also on the screen.

I was paying attention to the chat and forgot what I was trying to say. Sorry. Just get me. Oh, sure. Okay, great. Yeah, we'll catch me on the chat. So actually, why don't you do that? Because it's the chat. I was actually going to say what came up in the chat, but I'm going to expand on the chat so up to you. And we think that that is actually a good point. Pricing is pricing a risk in traditional world is so different from the DeFi world I even wondered whether most of web3 stakeholders think about such risks. Thank you.

I'm going to be the curmudgeon here. you know, DeFi is so different. Web3 is different it's international except on in bitcoin we have four groups that control most of the mining hash rate i.e. it's more concentrated than the traditional banking system. I… Because as I looked over the the output from Tokyo Block 10. The thing that kept going in the back of my mind was, who's going to pay for this?And this is kind of a pulriary to Shockey's law. Money's the answer. What's the question? And the answer is we have some very large, very well capitalized companies that are doing crypto ISAC. Because you know what it looks Just like the financial services industry, although for a lot of One could argue good reasons or maybe not so good reasons. They don't want to be part of FSI set?

which has problems. Many of our members are members of both. Right. Yeah. And so, for example, now I will actually start touching upon some of the questions. And thank you so much for starting the conversation. Cyber threats are kind of like mammalian dna I mean, uh, uh. a cat is very different than a human, but we share like 60, 70% of our dna And if we look at you know humans chimpanzees, it's all about 97% of our dna is shared. Most of the threats to the crypto

industry are going to be dealing with things like block this IP address. look out for this country who's attacking infrastructure, et cetera, et cetera. In other words it is can't get up there.

it's already covered by STIX and TAXII. And so if you wanted to create something new you're saying, oh, we're going to ignore 97% attacks on our industry. Probably not a good place to start from so that That's easily off the table, clearly not a due diligence. platform, something that fits into the ecosystem, which gets into another issue. Does information sharing need to be nationwide or global? kind of depends, again, being the curmudgeon when I got into this area I left industry, came into research all the academics were looking at, oh, how can we get the government to share information with companies? That was like the focus of academics. And I looked at it from a different section. I got into academia And we were very involved with What was the 2008 attack? It was like hacking the domain name system That's right.

Anyway, here's a big thing. And the thing that I realized was two things. One was, as someone will say, you want your investments to be where people aren't white space so if everyone's feeling how does government share with companies I'll do something different. But the other thing was quite often companies had better information than the government. You know who has more sensors in the field, the National Security Agency or Google? Yeah, how many orders of magnitude Google censors more than the NSA.

Now, first, say you can do things like kind of work on the who and wise. And that's where the question then becomes for the different ISACs. Remember, they're created by presidential policy directive and then law. That means they didn't get information so the US government could share with precise that certainly does share with fsisat. And likewise, GCHQ can share information with British entities. They don't like to share across. And so we do though have a worldwide model called first, which is basically where all incident responders. We're getting a trusted environment can share. So, ooh, it's one three it's different it's decentralized, except it's all the same. So again, do we really want to invent another mechanism.

One thing, though, I'm going to take this a little different first, clarification probably for Americans as well, MITRE doesn't run the CVE database. MITRE is under contract by CISA to run the CVE database. Do they have the capability of doing this? Absolutely. There are a lot of very well-paid, very experienced Crypto-related ones? Yes, that's awesome. Full disclosure, I've consulted. But the thing is that doesn't mean that doesn't mean… Oh, I thought you were meaning yes a lot of people doing this. That's right. You know, that we did not add a lot of value both in the what kinds of things are unique, you know, getting to your question. And then, you know, being part of the community.

Because… Yeah, why not? In fact, if you're reading the news I'm just going to say something bad. This is up for sale. This is actually being kind of, I wouldn't say pulled out of this, but again, just as MITRE is doing this under contract, the CISA, do not be surprised if in a few months you will see a contract coming out from this for a community-based organization from this. And

again, another place where I think BGIN can add value in ensuring that our distributed ledger technology, because if you're talking to the NSF, blockchain means milk the planet digital ledger technology means pool distributed computing.

I really appreciate that. And also, you're right. This is the perfect slide to foment, I think, the rest of the discussion. And I know that you're, I don't know if your hand is raised right now, but I know that it was raised earlier and I want to make sure that we get an opportunity to hear from you on the questions on this slide. If you have some thoughts, like I'll just take 30 seconds to explain the questions here for the broader group, but then would like you to answer any of these that you have some views on. Does the upfront question related to the stakeholders is about do responsible disclosure practices work in the crypto industry?

That is an interesting place where we talk about what is different in crypto versus the traditional space or what is the same, in fact, for both. The question in the top right asks about the new threat intelligence platform or something new. So a new type of platform, a new type of organization. Obviously, ones have been created. Any data format in the crypto industry, this is an interesting one where there's a lot of same information and there's a few unique ones, but areas where there have been some other standards efforts, like I remember right after we created the FATF travel rule and all the other FATF standards in 2019, there was like exactly one that I know of industry driven effort that created and published publicly the IVMS 101 standard, the intervast messaging system or whatever, standard, I guess that's what standard, yeah. For them to be able to share information, kind of like a swift message, but like what that looks like to comply with the travel rule. So that was interesting. And then, of course, a lot of the data, like we mentioned, digital footprint data often looks very similar. And in other cases, like, you know, I mean, crypto addresses aren't a part of a swift message platform, but we do have a lot of APIs pulling that information on a lot of other highly structured digital data. So curious about where there's data formats and standards that exist in the crypto industry that could be leveraged here. Does information sharing need to be worldwide rather than nationwide? A really good question we already got remotely that we talked about a bit. And then at the bottom, the two other questions. related to do MITRE or CISA or others have the capability of creating these CDE codes or mapping these uniquely to crypto related vulnerabilities or to long existing other digital footprint and cyber ones? And then do crypto businesses register for CNA, CVE numbering authority? So these are the broader questions that I'd love to stoke some discussion with. Can I turn to you first? Any reflections?

Yes. So as we look at this diagram, it's 2D, too dynamic, two dimensional. But what someone mentioned, I was thinking it's actually three-dimensional where, for instance, the nation state, there's multiple countries. Just to give you a little bit of background, I used to work for an organization called ICANN, Internet Corporation of class names and numbers which manages all the IP addresses and a couple of domains. And they actually deal with countries, all the countries, meaning all the countries that have CCTLDs right. And I was wondering, is BGIN

going to handle everything like all the countries we're aiming for international, for the international standard, right?

So that's more of a question or something I wanted to ask the room because not all the countries are… That's a good question where our executive director for beginners. I know it'll be late to… But that will be in the last session. Okay. Sorry.

All right, so stay tuned. Stay tuned. And of course you can discuss sound too absolutely and and why there's such a diverse and multinational representation that is present here in this room demonstrates the issue when you have technology and business operations that are highly distributed and sprawling around the world, we inherently need to think about standards hopefully in an international way and context, but ultimately like you know we have ISO which is the International Standards Org, but we also have others like like ISO existing doesn't obviate the need for organizations like ICANN or like ITU and others. So I think thinking about what the right I guess dynamic or focus is and will be for being excited that that will be discussed later in session today. Then any other, so any observations from this group here about, maybe let's start with this first one because I am very curious about thoughts here about whether responsible disclosure practices work in the crypto industry. What is unique or special, including if you have used, many of you are from the crypto industry where maybe you feel that you are a responsible actor, but you've had a hard time building trust in the eye of government authorities that maybe discount you or see some broader challenges and trends that occur across the industry and issues that you have. Or maybe you are part of driving an information sharing organization, so you know exactly what responsible disclosure and information sharing looks like across the industry. Any observations from the group about does responsible disclosure across the crypto industry, how does recognizing, acknowledging vulnerabilities and sharing them look different or the same in the crypto industry? You already talked a bit about how some of the practices are the same, like an open source platforms, people identify vulnerabilities and they worked to patch it. So in some cases, yeah, it's happening. Other thoughts from this group about whether the first step of disclosure and identification works with crypto stakeholders and what doesn't work.

Including if it's specific stakeholders that just need to be driven, like what's wrong with the disclosure and identification part of vulnerabilities? In crypto that may need to be addressed.

I've got a couple of observations I can share. And let's just talk about the act of vulnerability Disclosure. Let's not talk about the act of patching vulnerabilities because that's got its own challenges as we touched on earlier.

I would disagree. I would push back on a couple of things that someone said about crypto being different and the same. Yes, we need to leverage and learn from best practices and Web2 IOCs and should not be ignoring what we've learned over all these years, but there are differences in crypto. We can talk more about that. But if there's one area that I think might translate nicely into blockchain and crypto, that is best practices around responsible vulnerability disclosure. You do

see the leading institutions with their own bug bounty programs already. They exist. So if you go to hack on Coinbase you know you know who to call, you know who to disclose your vulnerability to. Not that Coinbase would have a significant vulnerability. You know what I'm saying?

We do see extortion on chain, which we've seen in web two right and what what is happening now is a vulnerability is discovered it is exploited. The attacker is stealing assets. The attacker is then notifying the responsible party who's responsible for the maintenance and addressing that vulnerability and brokering a deal, negotiating a deal where 90% of the assets will be returned and a 10% payment will be retained by the attacker. That is not okay, but it is happening and we have seen that play out before in Web2.

So I think that the basic models where we've come with responsible disclosure, the acknowledgement on both sides that there's a period of confidentiality to allow a vulnerability to be fixed, that construct translates the bug bounty model translates the bounties are much higher in crypto. It is what it is, but the model exists.

I think the thing that we should keep in mind, and this was said to me two days ago by an expert is that Blockchain is basically one big bug bounty like when a vulnerability is exploitable on chain, the bounty is right there for the taking like immediately and you can monetize that now you can, you know these adversaries, these black hat hackers can liquidate very, very quickly. and the like maybe in web two where, okay, you've downloaded a database and it's a bunch of, you know, PII and you've got to go to the dark web and find a marketplace and sell it. There's a whole process to that. In crypto, the reward is right there for the taking, hence these really short windows of time to exploitation and hence the big bounties in crypto. So that's just something to keep in mind. The asset, the target, the loot, if you will, is liquid. Immediately. And that's going to impact things like incentives and time to develop exploits and all that kind of thing.

But stepping back on responsible disclosure, I actually do think the lessons that we've learned do translate quite well into crypto. And what we've got to do is really educate, right? Educate the stakeholders responsible for maintaining this infrastructure and addressing vulnerabilities to look at things like bounty programs and identifying resources that are accessible to industry so that when vulnerabilities are discovered they can be, they know who to reach out to.

All right. Other thoughts? I'm just going to call on you. Do you have any observations on responsible disclosure or data formats or anything on some of the specific issues here that we're trying to walk through the questions in purple, just any thoughts you want to share?

Very interesting. I can share what I'm trying to understand. However, this is probably another question for cyber security framework. However, at some point in the framework of blockchain facilitated transactions there is a question of ability to like tracking the transacting parties with any information of their identity and on disclosed discussion about that like a little bit of

information is primed. and to is it the like… Where do you see any kind of potential solution for the framework that will deliver high level of cybersecurity and at the same time, I don't know, privacy but removing this anonymity to be able to to track all theirs and transacting parties. Because to the best of my understanding, it's impossible for long machine. Is it only possible when we have intermediaries? and then regulate dermicaries to be to be asked after some KYC and any other regulation or is there any technology solution that might be applied on the blockchain to deliver it. It's not for cyber, it's more for regulation, I would say that for cybersecurity, more for regulation purposes. But I think you may refer to this.

Yeah, no, I love the question you brought up like brings us back to something very tangible, which is, okay, the whole point of this construct of identifying vulnerabilities is to be able to do something about it, to be able to patch that vulnerability, to stop it from being exploited, to potentially get funds back from certain institutions or demand that they put in place or not demand them, but incentivize them and thinking about whether or not incentives and motivations exist sufficiently in the crypto space to make full use of this framework to actually identify patch vulnerabilities, and then potentially to take action to do something about it, which could mean getting money back, it could mean holding accountable bad actors and routing them out from your ecosystem. That's a much broader discussion about what should we do when someone has exploited these vulnerabilities, which I think would be a very fun follow-on discussion. So I think that's a really great point of discussion. Also, do you have any thoughts, Yar?

No, just maybe, I have a question actually to the Crypto ISAC. If you have any members like analytics companies who also sometimes i think discover vulnerabilities and I wonder if they also report them through the system in a way or about the actors, bad actors on the blockchain, right? I checked your website and didn't see any other analytics companies yeah so…

Thank you. We do have a relationship with Chainalysis, TRM, Elliptic, etc. And right now, we are engaging on research engaging on projects, but those companies are not so much part of our membership as much as what you might consider to be the vendor landscape. We consider that to be supply chain actually; we try not to compartmentalize vendors in one bucket. I know a lot of those analytics companies spend a lot of time and investment in tagging addresses on chain, working on attribution back to organizations along reputation and risk profiles of those organizations, whether they be exchanges or threat actors. So a lot of information available via those analytics companies is along those lines, tagging that infrastructure.

I have not yet had a lot of conversation with the analytics companies about software vulnerabilities, but I have no doubt that there are research teams internally within Chainalysis and others that are focused on that space.

Yeah, thank you. I saw there was a comment virtually, and then a comment in the room.

Yep. Hello, everyone. I'd like to point out the points that we see of open source applications. And I think these kinds of vulnerabilities should be addressed by the signers. I see the difficulty in forcing this open-source community to create a patch as soon as possible. This is not controlled by a major vendor, and these kinds of mortgage lenders have nothing to do with this kind of situation. I wanted to connect. I think the unique points of the tech are safety and that they have an open-page application that enables work movers to connect automatically to the website application. So I think we should address this problem.

Thank you. Those are some really interesting insights and corollaries to how we should be thinking about it through open source security and partnership constructs. And also, thank you for those insights about where you think some responsibility or action could exist for pushing security patches. In the room, we had a comment.

Hi, just going back to your question, I can talk a little bit about our practice in that regard. We do have members of our research team who are active in some of these white hat birds, SEAL 911, and those kinds of other groups in the community that look for vulnerabilities and also address exploits once they happen. Our main practice when an exploit occurs is to directly inform the company itself. And also, if their services are being co-opted for any sort of money laundering or other various frequencies, but it's not our practice currently to report this to any sort of centralized entity. Do you have thoughts on the value of that? Should there be one?

I think it would be valuable. I think it's something that we would be open to. Also, part of BGIN's thesis. But I also think that, you know, that would be something that we would have to have a conversation about directly. And I think that in a lot of cases, you know, we do have customers all over the world, but we may not be as familiar as a team with some of the reporting measures in the US, for example.

Yeah, thank you. And I think this highlights how I think I want to help stoke discussion for the rest of us. So I know we've identified a couple of the issues, opportunities, and already existing practices related to responsible disclosure, also identified some interesting issues with incentives and organization around decentralized communities that may cause some challenges with making that terribly efficient, but it does exist. Incentives and motivations do work for enabling responsible disclosure. I'll now share that information. We know that there are existing threat platforms. I've not heard a ton of discussion, especially about data format in the crypto industry. Some people have mentioned STIX and TAXII, and to show my cards, yes, I generally feel that this standard already exists. Why not use it when so much of that digital footprint info is the same? Who cares what I think? What does the industry think? What do you guys think? New standard, leverage, and adapt the existing one? There is a pretext field in STIX and TAXII. Is it just adapting that and creating that, or should BGIN try to help drive or identify another place where some new standard needs to be created for enabling the machine-readable, interoperable sharing of that threat info? Also, think about how those formats look different or the same,

because I know some of it is digital info. It's a little bit different about digital blockchain infrastructure, and some of it's money info, which is different. So curious how you guys think about that. Yes, there.

Thank you. So part of why STIX and TAXII won the war against CybOX and IODEF was that CybOX and IODEF were really, really easy for humans to understand and read, and all that. And IODEF did IP addresses and domain names, and that's it. STIX is almost impossible for a human to read. Originally, it was XML; now it's JSON. And it is extensible. So it's not a case of do we need something new? But yeah, it's not different, but there are some things that are unique. And so you just do it. You go to OASIS because you want everybody to be able to...

I love views from the groups, let's imagine that we did create this. The organization — and again, sorry, I should have highlighted upfront, all these views are just my personal views. Just me trying to be a facilitator of the discussion as BGIN thinks about the next steps in dealing with data formats.

In the crypto industry, do we have a consistent format? I know that as an agency, when I received information, a lot of it looked similar, and a lot of it didn't — across different chains, across different analytics firms. To what extent do we have common data formats already in existence? To what extent is that a totally doable and knowable thing? Like, could we create this? How much already exists? How much needs to be created? I guess those are my three questions about data format. How much lift is that based on what's currently out there?

I've been living and breathing STIX and TAXII for the last six months. And I completely agree. Let's just extend STIX and TAXII. You know, my day in, day out is risky addresses, SHA hashes, whether it's a smart contract hash or a transaction hash or a wallet hash. STIX and TAXII do not specifically have a field dedicated to that yet. I would love to see that happen.

We are working around that right now with this free-form text field. That puts a bit of a burden on us because we've got to create these custom objects and special rules for handling. You have to hope that the threat intelligence platform on the other end of the conversation is doing the same thing — often, it's not. So you go through this process. The engineering involved to do the manual extension to STIX and TAXII is costly. It's taking us time. I would love to see OASIS extend the standard to recognize addresses for what they are. Maybe there are two or three different types.

And by the way, I know that the crypto ISAC is not the only ISAC dealing with limitations with STIX and TAXII. Everybody loves it, everybody's adopting it, but there are other ISACs with their own unique sources of threat intelligence and their own journey to extend STIX and TAXII. But I think there is consensus that STIX and TAXII just need to be extended. We don't want to reinvent that wheel.

Oh, yeah. I mean, as someone that is active in the IT department, my take is don't reinvent the wheel. That's absolutely necessary. And if we need something special for our use case, we can always go to ITFM and ask for a change.

Gotcha. And maybe one additional comment about this: there is a very good precedent recently when IBM joined with others and created a cryptographic bill of material standard specification, which is an extension of an SBOM specification. So that is a good example that could be applied to this case as well.

So as a question: how important is it for the scope of the ISAC to include operational best practices for stakeholders? That's their job. Chaordic. Oh, chaordic. I was amazed that you knew that word. So if you're not familiar with that, that was coined by Dee Hock. Does anyone know who Dee Hock was?

How many of you carry a Visa card today? Dee Hock is the founder of Visa. The reason Visa took off in the mid-60s — and I'm older, but I wasn't there, I promise — is that participating banks issuing credit cards had all of these operational variances. It was like six standard deviations operationally. So before anything was done at a technical vulnerability level, all members of the association — and I would contend that as much as technically the ISAC started in '98, I would say the first real financial ISAC began in 1968 when Visa was formed because it got the associates member benefits to form an association for the first purpose of sharing best practices first and then enabling technology second.

So it was a way to raise capital quickly, galvanize, and become like the focal point. And I just share that again as an observation historically, that leaning as much on technical vulnerabilities as operational risk can go a long way towards galvanizing.

Can I add one thing to how to make that information shared? If they can do something... You might not think that number, but it's 45 days for these ADAs. And, you know, they're not doing that. So this is the one doing that for genetic data. But, you know, it's a kind of that. So, you know, lower universities should do some education, you know, engaging as students and so on to understand the information shared. That is an easy thing to do, especially in the past three years with probation issues.

But on the soapbox coming first of the day, which I think, double down on using what's existing out there. I mean, one of the priority purposes for this is to keep the ecosystem safe and build and extend trust in the ecosystem. There will be enough frustration and friction along the way, so I would again resist the urge to try and think of something new. Certainly, getting to this, you know, took a while, as I recall. you will know better, probably, to get this open data field in STIX and TAXII. But, you know, I think someone has mentioned privacy.

As far as I understand, the privacy concerns around user identification have been drastically reduced, if not entirely eliminated, almost, except for the open text field with STIX and TAXII. This has allowed for a lot of information sharing around cybersecurity information to flow over the past decade or so around the CISA framework.

Similarly, the STIX and TAXII framework is an international framework. Many of the ISACs, if not all of them, have international partners. I understand some sense of the national concerns around the establishment of CVEs and the NVD, but I think looking at who the stakeholders are and the decades of experience with that process, I would be least concerned about the national aspect, except for in cases of the NPD...

I'm curious about the privacy implications. What does that mean? I think it was more that STIX and TAXII allowed for or facilitated the reduction of concern around cyber threat indicator sharing.

because the STIX and TAXII fields, as far as I recall, were quite extensive. Remember, there are many hundreds of them, something like 144, and CISA uses about 88 or 44, something like that. When we were looking at how to incentivize the sharing of cyber threat indicators, there were significant concerns from the privacy community around the sharing of that data. Leveraging the use of STIX and TAXII, as I recall, helped reduce these concerns.

Was that because of the risk of personally identifiable information (PII) being caught up in that threat intel?

Yes. I can actually give a concrete example, which is why we have such customizable security on these fields. The use case that was given to me early last decade was: I receive a phishing email, I report it to my bank, and the bank says, "Oh, hey, this is probably a campaign, so we ought to share it through FS-ISAC." Then the bank goes, "Whoa, you've got our customer's email address, PII." And by the way, it looks like we're sending phishing emails. Initially, they would redact the “to” field, redact the bank name, and essentially redact so much that the shared information was rendered useless.

So that's where a lot of effort went into customizing fields, because there were a lot of concerns from the privacy community that this could be used for governmental purposes or other sensitive applications. Not to point at any particular stakeholder, but this also brings up the topic of extending STIX and TAXII. On the one hand, you would expect it to be very...like, is a wallet address considered PII in Europe? That's a good question.

Yes, they identified that, and suddenly it’s, "Well, now it is PII." I’ve seen some people state that if it’s essentially the equivalent of a bank account — and that’s debated — whether it’s hosted or unhosted. Either way, it’s an account that’s either personally hosted or hosted at another entity. Is

that something that you consider PII? It depends if you publish that information publicly on a ledger.

And so, now PII doesn't inherently mean that it's private; it just means it's personally identifiable. How is the consideration for protection around that? Privacy issues are one area we need to dig into in this discussion because...

Sorry, Eric, can you finish your thought? Because as we're closing in on the last five minutes here, for information sharing to work — which is the point of this discussion — something has to be done with the information. Information sharing that doesn't lead to any actions being taken isn't effective. So further discussions, I know, are part of the next phase, as well as broader discussions here at BGIN on what it takes to create the incentives, motivations, and identify the right stakeholders who are positioned and have the political will to act. This is crucial to making this process worthwhile. But this is a first step: getting the information to the hands of the right people.

To close this discussion based on the interesting points on privacy and other aspects, the nature of the data points back to data format. We've talked a bit about existing standards and frameworks that we can use. The unique considerations of sharing digital data versus financial data, including existing formats, are also important. If anyone has final insights or reflections to close this discussion with actionable points for BGIN, I would love to hear them.

I'm not too familiar with the ecosystem around STIX and TAXII. I'm more familiar with electronic health records, all the data criteria, and ensuring that vendors exchange messages that way. So I don't know much about the ecosystem here, but it may be worth looking at the data types exchanged between pharmacies, doctors, and hospitals, or the standards there, to see how they're dealing with privacy, personal information, and security. Maybe take some lessons from that.

Finishing point. Any other observations on existing standards or frameworks for sharing financial data, healthcare, or other types of protected records that the crypto community could consider? How can we marry financial info with cyber info?

One cool thing about the crypto industry is that we actually have technology that can improve this process. In your question, I was wondering if it would be enough just to share the smart contract address. Is that sufficient, or do you actually need to specify the vulnerability in the smart contract in this information-sharing protocol? That's an open question I have. Secondly, zero-knowledge proof technology is quite interesting in this context because it provides an authentication layer for accessing the underlying information, potentially improving the process. Information could be shared automatically, with an authentication layer or the ability to unwrap the proof protecting PII or other sensitive data.

Thank you. To close out, are there any final punchy calls to action from anyone in the room or our team discussants on how we can put this into action? What should BGIN most focus on and dissect next as part of this discussion?

I'll turn to you because, if BGIN can work with OASIS to get addresses included in STIX and TAXII, that would be very helpful. Then, we need all the commercial threat intel platform providers to adopt the latest standards.

And of course, in the next session, we will discuss and react to the insights shared here.

Perfect. Are we at time? Great. Thank you so much to everyone virtually for being such vocal participants and to everyone here for this great discussion. This was very helpful. This is something the US government has been looking at, and many of us in this room have thought about this as one of those concrete areas where we could make a meaningful impact sooner rather than later. Thank you all so much for helping us examine it. More to follow. I'll turn it back over to Takaya.